

BleepingComputer Forums → Security → General Security



Google is Actively Deleting Posts and Censoring Their Own Developer Forums

Started by Bitu79, Today, 12:34 PM

Bitu79

Posted Today, 12:34 PM

Broken Access Control: "Deleted" Interaction API sessions remain persistently accessible and bypass the 1-day TTL purge

Gemini API

Bitu79 September 8, 2026, 2:22pm1

<https://gist.github.com/istokovicsgyorgy79-jpg/a6f0b4242e3c391bb295193eda010715>

(<https://gist.github.com/istokovicsgyorgy79-jpg/a6f0b4242e3c391bb295193eda010715>).

TITLE: Google's Data Deletion Fraud: How they are scrambling to delete all evidence of their fake "Delete" button in AI Studio

POST BODY:

Google is actively deleting posts and censoring their own developer forums to hide a massive data retention and privacy violation within Google AI Studio. When you click "Delete" on a prompt, the system fakes a 404 error, but your sensitive data is kept permanently on their backend servers. They lie in their documentation about a "1-day deletion for free tiers." I proved it, reported it to their Bug Bounty (VRP) program, and caught their moderators engaged in live, coordinated censorship to cover it up.

Since they are trying to silence this, I am making my official Google Issue Tracker ticket public for everyone to see.

Read the evidence yourself.

:police_car_light: GOOGLE ISSUE TRACKER EXPORT :police_car_light:

Issue ID: 558605310

Title: Broken Access Control: “Deleted” Interaction API sessions remain persistently accessible and bypass the 1-day TTL purge.

Reporter: gabor_gabor@freemail.hu

Status: New

Type: Customer Issue

Priority: P4 | Severity: S4

Component: AI VRP

Description

Created by: de...@google.com on behalf of gabor_gabor@freemail.hu | Sep 8, 2026, 1:22 PM

Summary: Broken Access Control: “Deleted” Interaction API sessions remain persistently accessible and bypass the 1-day TTL purge.

Note: The vulnerability is known to third parties!

Program: Abuse VRP

URL: <https://aistudio.google.com/> (<https://aistudio.google.com/>).

Vulnerability Type: Bypass of Authorization

Technical Details:

Google AI Studio and the underlying Interactions API suffer from a severe state-desynchronization and broken access control vulnerability. When a user deletes a chat session via the UI, the system merely moves the client-side .json metadata pointer to the Google Drive Trash. It fails to send a DELETE or DROP signal to the backend storage. Consequently, the server-side conversation state, token memory, and context are never physically purged, overriding the documented 1-day TTL for Free Tier interactions. The backend essentially orphans the active session instead of securely destroying it.

Attack Preconditions:

To exploit this, an attacker only needs to recover or intercept the victim’s discarded client-side .json pointer (e.g., via local machine access, backup extraction, or shared drive misconfiguration) containing the interaction_id. Because the backend fails to validate the deletion status of the session, possessing the pointer grants immediate access to the orphaned backend data.

Reproduction Steps / POC:

Open Google AI Studio and generate a multi-turn chat session containing sensitive test data.

Click the “Delete” button on the prompt within the AI Studio UI.

Navigate to Google Drive, locate the associated .json pointer file in the Trash, and select “Empty Trash”.

Wait for a duration exceeding the official 1-day TTL auto-purge (e.g., 5 days).

Use the official Google Drive File Recovery tool to restore the discarded .json pointer.

Open the restored .json file in AI Studio.

Output: The chat session immediately resumes with 100% of the historical context, memory, and tokens loaded from the backend server, proving the backend data was never destroyed and the TTL purge is inactive.

Impact Analysis:

Impact: Sensitive Information Disclosure & Persistent Session Hijacking.

If a user believes a highly sensitive conversation (containing PII, proprietary source code, or API keys) is permanently deleted via the UI, they assume the data is securely destroyed from Google's servers. However, a malicious actor who gains access to the victim's local machine, backups, or recovered drive files can effortlessly resurrect the entire "deleted" session from Google's backend. This violates the core security principle of secure data destruction and leaves supposedly purged sensitive data permanently vulnerable to unauthorized retrieval on the server side.

Comments

Comment #2 | sp...@google.com | Sep 8, 2026, 1:22 PM

NOTE: This is an automatically generated email.

Hi! Many thanks for sharing your report. This email confirms we've received your message. We'll investigate the issue you've reported and get back to you once we have an update...

Comment #3 | gabor_gabor@freemail.hu | Sep 8, 2026, 1:29 PM

Reproduction Steps / POC Videos:

PC Test: <https://youtu.be/LBQfNbPCxQw> (<https://youtu.be/LBQfNbPCxQw>).

Android Test: <https://youtu.be/8Pg-7eNPUWM> (<https://youtu.be/8Pg-7eNPUWM>).

Live Restoration Proof:



Videólejátszó konfigurációs hibája

Hiba: 153

Videó megtekintése a YouTube-on

További információ

Hiba: 153

What you will see:

The prompt returns. The chat continues. The context is still there. Nothing was deleted from Google's backend servers. This proves that Google's backend intentionally keeps the chat session fully active and accessible, even after the user presses 'Delete' and purges the Drive trash.

Comment #4 | gabor_gabor@freemail.hu | Sep 8, 2026, 1:46 PM

Lack of Audit Trail and Insecure Recovery Notifications (Blind Recovery State):

The platform's data lifecycle vulnerability is compounded by a total lack of auditability during the recovery process. The automated notification email sent by the Google Drive File Recovery service merely states that "files were restored successfully," but fails to provide an audit log, cryptographic hash, or a specific list of the recovered file IDs or filenames. From a security architecture standpoint, this constitutes a Failure to Provide an Actionable Audit Trail (CWE-778). The user is completely blinded to which persistent server-side prompt pointers have been resurrected from the backend.

Comment #5 | gabor_gabor@freemail.hu | Sep 8, 2026, 1:56 PM

Inconsistent Data Lifecycle Indicators and Critical UI Misalignments:

The Object Mismatch (Prompt vs. Pointer): The AI Studio dialog explicitly warns: “Move prompt to trash — Are you sure? Your prompt will be permanently deleted after 30 days.” Technical reality: The actual prompt object and context reside entirely on persistent backend systems. The only entity moved to Trash is a client-side metadata pointer.

The “Irreversible Deletion” Dialog vs. Active Recovery Window: Emptying the Drive Trash triggers a modal guaranteeing: “The item will be permanently deleted and cannot be recovered later.” This is factually inaccurate. Google maintains a 25-day disaster recovery window where the pointer remains fully restorable, instantly reconnecting to the unpurged backend session. The UI misrepresents both the scope (pointer vs. data) and the permanence of the deletion command.

(Attached Screenshots: 2026-08-27 075955.png, etc.)

<https://archive.ph/2soXy> (<https://archive.ph/2soXy>)

<https://archive.ph/4YAi4> (<https://archive.ph/4YAi4>)

Képernyőkép 2026 08 27 080037 hosted at ImgBB — ImgBB

Képernyőkép 2026 08 27 075955 hosted at ImgBB — ImgBB

Képernyőkép 2026 08 27 075936 hosted at ImgBB — ImgBB

Képernyőkép 2026 08 27 075919 hosted at ImgBB — ImgBB

Comment #6 | gabor_gabor@freemail.hu | Sep 8, 2026, 2:08 PM

Contradictory Documentation Sources:

Archived evidence: <https://archive.ph/AttI8> (<https://archive.ph/AttI8>) | Logs and datasets | Gemini API | Google AI for Developers

:one: AI Studio Docs (UI / Web Interface):

Makes the user believe that emptying the Drive Trash permanently destroys the data. My POC proves the “Delete” button only discards the JSON pointer and never touches the server.

:two: Gemini API Docs (Backend):

States that store=true is the default, but explicitly promises that data for Free Tier users is automatically purged by the system after 1 day.

The Direct Contradiction: In my video evidence, 5 days passed since deletion. If the documentation were true, restoring the pointer on day 5 would yield a “404 Not Found” backend error. Instead, the chat loaded completely intact.

Comment #7 | gabor_gabor@freemail.hu | Sep 8, 2026, 2:13 PM

Direct Interface Contradiction within AI Studio Log Settings (/logs):

The settings panel displays a mandatory retention period: Retention: 55 days (Default). The privacy toggles to disable Interactions API storage are greyed out with the warning: “You need an active billing account to enable logging.” The platform claims a 1-day Free Tier TTL in developer docs, displays a 55-day retention in the UI, and enforces backend logging by locking the opt-out toggles behind a paywall.

(Attached Screenshot: 2026-09-06 191250.png)

Wayback Machine

Comment #8 | gabor_gabor@freemail.hu | Sep 8, 2026, 2:26 PM

This is not a UI bug. This is a severe data deletion and data retention failure on the backend. The developer documentation explicitly guarantees a 1-day TTL for Free Tier data. My POC proves that the backend data remains fully intact and accessible after 5+ days simply by restoring the client-side pointer. This means the backend purge scripts are either failing or intentionally non-existent.

Comment #9 | gabor_gabor@freemail.hu | Sep 8, 2026, 2:38 PM

Conclusion: Intentional Pseudo-Deletion and the Deceptive 404 Error

This is not a “broken” backend deletion script. An actual backend data destruction script for this action simply does not exist by design. The entire deletion process is a visual placebo based solely on pointer manipulation.

When a user empties the Trash, the Google AI Studio UI throws a “404 Not Found” error. This error leads the user to believe the data has been purged. However, my tests prove this 404 is merely a frontend response reacting to the missing Drive pointer. By utilizing the Recovery Robot to restore the .json pointer, the frontend instantly reconnects to the API.

The system is architected to provide the illusion of permanent deletion (via a deceptive 404 UI state) while intentionally keeping the supposedly destroyed sensitive data perpetually retained on Google’s backend.

Note on Platform Censorship:

I initially attempted to discuss these technical data-retention inconsistencies on the official Google AI Developer Forum. Shortly after posting, approximately 70% of my posts detailing these mechanics were systematically deleted by moderators without explanation. I have full video documentation of this live censorship. The active suppression of this issue on public developer channels strongly suggests internal awareness of this data retention failure.

Public Archive Evidence of the Deleted Threads:

[https://archive.ph/https://discuss.ai.google.dev/*\(https://archive.ph/https://discuss.ai.google.dev/%5C*\)](https://archive.ph/https://discuss.ai.google.dev/*(https://archive.ph/https://discuss.ai.google.dev/%5C*))

Comment #10 | gabor_gabor@freemail.hu | Sep 8, 2026, 3:09 PM

The following video evidence provides a comprehensive, real-time documentation of the active, coordinated censorship and suppression of my reports by platform moderators, further substantiating the systemic effort to conceal the technical data-retention failures detailed in this submission.

[https://archive.ph/Oa8v4_\(https://archive.ph/Oa8v4\)](https://archive.ph/Oa8v4_(https://archive.ph/Oa8v4)).

Legal and Technical Refutation of Google's "Data Retention / Disaster Recovery" Defense

Google's anticipated defense—that retaining deleted data in the background is a deliberate safety feature for recoverability—collapses completely when scrutinized under the General Data Protection Regulation (GDPR) and the technical guidelines of the European Data Protection Board (EDPB).

I. The Relevant Legal Framework (GDPR)

1. GDPR Article 17(1) – Right to Erasure ('Right to be Forgotten'):

"The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without undue delay..."

Legal Meaning: Erasure cannot merely mean hiding the data or making it invisible on the frontend (Soft Delete). At a technical level, the controller must execute a process that permanently prevents the future restoration and active processing of the data.

2. GDPR Article 5(1)(and (e) – Purpose Limitation and Storage Limitation:

"Personal data shall be kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed..."

Legal Meaning: Once the user terminates the purpose (by explicitly deleting the chat), the data must be completely removed from daily, active production environments.

II. Why Google's "Retention" Defense Fails Legally and Technically

In internal VRP communications, Google defends this practice by stating it is "Intended Behavior" and that data "persists on our backend" so legitimate owners can recover it. This defense fails on the following three legal-technical grounds:

1. The Lack of Strict Restriction and Isolation (The "Uninterrupted Execution" Paradox)

While the GDPR and EDPB guidelines allow a company to temporarily retain deleted data in backup cycles for legitimate security purposes, the law strictly requires that the data must be “Put Beyond Use.”

The Legal Requirement: During the retention period, the data must sit in a passive, encrypted archive (cold storage). Live production software (like the active Gemini AI model) must not have direct, functional access to it.

The Proven Failure: My forensic testing proves that days after emptying the Trash, simply restoring a tiny client-side .json pointer file from Google Drive causes the chat session to resume instantly and seamlessly with the backend server. Quarantined, backed-up data does not respond in milliseconds. This is physical proof that Google never restricted, isolated, or locked the data; they left it in an active, online database (“hot storage”). If the operational link was never severed, from a data protection standpoint, no legal erasure took place.

2. Intentional Deception and Breach of Transparency (GDPR Article 12)

GDPR Article 12 mandates concise, transparent, and truthful communication. The software UI must accurately reflect technical reality.

The Proven Failure: Google Drive’s own Activity Log explicitly confirms to the user: “Permanently deleted an item.” Lying about permanent destruction on official system logs while internally admitting that the data is intentionally kept actively accessible in the backend constitutes deliberate misinformation, a Deceptive Design (Dark Pattern), and bad-faith data processing. Google cannot legitimize a deceptive soft-delete as a “security feature” when its own UI officially denies the existence of that very feature.

3. Bypassing the Documented 1-Day TTL Promise

The official Gemini API developer documentation explicitly guarantees a 1-day (24-hour) Time-To-Live (TTL) auto-purge mechanism for Free Tier interactions.

The Proven Failure: If the technical documentation promises a 1-day destruction cycle, yet their internal systems (evidenced by the 55-day AI Studio setting and the ability to restore live sessions days later) actively retain those sessions, Google is committing a breach of contract and intentional corporate deception.

Conclusion:

Google is not executing a deletion or a secure backup procedure; they are executing a “Placebo Deletion” designed to unlawfully retain active access to user data on production servers.

 Edited by Bitu79, Today, 01:02 PM.

[Back to General Security](#) · [Next Unread Topic](#) →

[BleepingComputer Forums](#) → [Security](#) → [General Security](#)